Headers

why we need something called header why not just sent those info in the URL or the Body ?

Metadata vs. Payload

Efficiency

1. Headers act as Metadata (information about the data). The Body is the actual Payload (the data itself)
2. Network components like Load Balancers, Proxies, and Firewalls need to read the request destination and security tokens without decrypting the entire Body.
3. The "Parcel" Analogy
when you send a parcel, you write the address and phone number on top of the box, not inside it.

الـ Headers هي "بيانات عن البيانات". السيرفر محتاج يعرف معلومات زي (مين اللي بيبعت؟ نوع الداتا إيه؟ هل الداتا مضغوطة؟) قبل ما يفتح الـ Body ويقرأه. ده بيوفر وقت ومجهود كبير على السيرفر.

Type Headers

1. Request Headers

1. Host
Host: example.com
2. User-Agent
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
3. Accept
Accept: text/html
4. Accept-Language: en-US
Accept-Language: en-US
5. Connection
Connection: keep-alive
6. Cookie
Cookie: sessionid=123456
7. Authorization Authorization: Basic <base64(username:password)>
7.1 Basic Authentication
7.2 Bearer Token like JWT token / OAuth token
7.3 API Key json web token

Request Example

security problem !!

Base64 ليس للتشفير بل مجرد Encoding يعني أي شخص يلتقط الترافيك يمكنه فكها بسهولة

so we use HTTPS

2. Representation Headers

1. Content type
Content-Type: text/html
Content-Type: application/json
2. Content Lenght
Content-Length: 348
3. Content Encoding
البيانات مضغوطة ولازم تتفك
Content-Encoding: gzip

3. General Headers

1. Cache-Control
لا تستخدم نسخة مخزنة، اطلب الصفحة من السيرفر.
Cache-Control: no-cache
احفظ بالنسخة في الكاش لمدة 3600 ثانية (ساعة)
Cache-Control: max-age=3600
2. Date
Date: Tue, 08 Mar 2026 12:30:00 GMT
3. Connection
Connection: keep-alive

4. Security Headers

1. Strict-Transport-Security (HSTS)

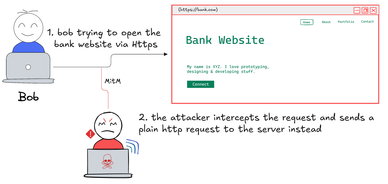
الهيدر ده يجبر المتصفح على استخدام HTTPS فقط مع الموقع.

Strict-Transport-Security: max-age=31536000; includeSubDomains

Even if the User Enter HTTP

The browser will automatically convert it to:
(https://example.com)
prevent SSL Stripping Attack

Man-in-the-Middle
SSL Stripping Attack

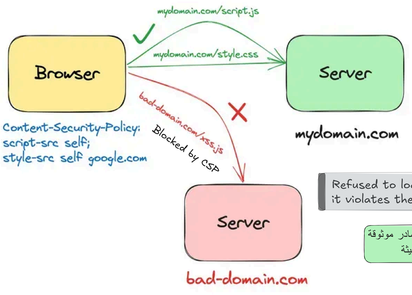


2. Content-Security-Policy (CSP)

يحدد المصادر المسموح بها للموارد

Content-Security-Policy: default-src 'self'; script-src 'self' https://trusted.com

Prevent Cross-Site Scripting (XSS)



Console Message
Refused to load the script because it violates the following Content Security Policy directive

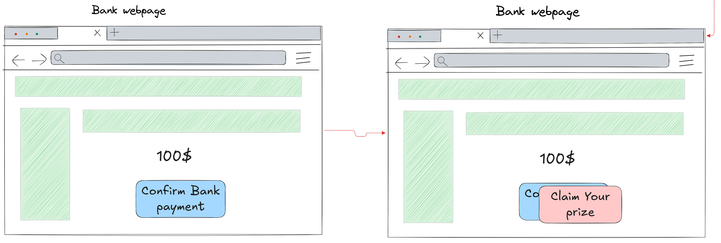
المتصفح يسمح بتحميل الملفات من مصادر موثوقة
يمنع الملفات من مصادر خبيثة

3. X-Frame-Options

يتحكم إذا كان الموقع يمكن تحميله داخل iframe

X-Frame-Options: DENY

Prevent Clickjacking



4. X-Content-Type-Options

Prevents the browser from trying to guess the MIME type of a file (MIME type sniffing)

X-Content-Type-Options: nosniff

MIME Sniffing
This process makes the browser guess the real MIME type of the file.

5. Cookies Security Flags

Set-Cookie: sessionId=abc123; Secure; HttpOnly; SameSite=Strict

Flag	Job
HttpOnly	يمنع JavaScript من قراءة الكوكي
Secure	يرسل الكوكي عبر HTTPS فقط
SameSite	يمنع هجمات CSRF

If a website does not contain security headers, this is called:
Security Misconfiguration
This is part of:

OWASP
Open Web Application Security Project